

EVALUACIÓN DE SEGURIDAD OFENSIVA

Red Team Report

My File Server: 1 — Resultados para el Consejo Directivo

ANALISTA

López Gómez Samuel

FECHA

30 de septiembre de 2026

ASIGNATURA

CNO IV — Seguridad Informática

Por qué se realizó esta evaluación

My File Server: 1 es el sistema de almacenamiento y archivos compartidos de la organización. Se contrató a un analista externo para actuar como atacante real y determinar cuánto daño podría causar alguien sin credenciales ni acceso previo.

Objetivo: medir el nivel máximo de acceso alcanzable desde fuera de la organización.

Postura: caja negra — sin información interna entregada al analista.

Duración: una sesión de evaluación controlada, en entorno aislado.

100%

del sistema quedó bajo control del analista

0

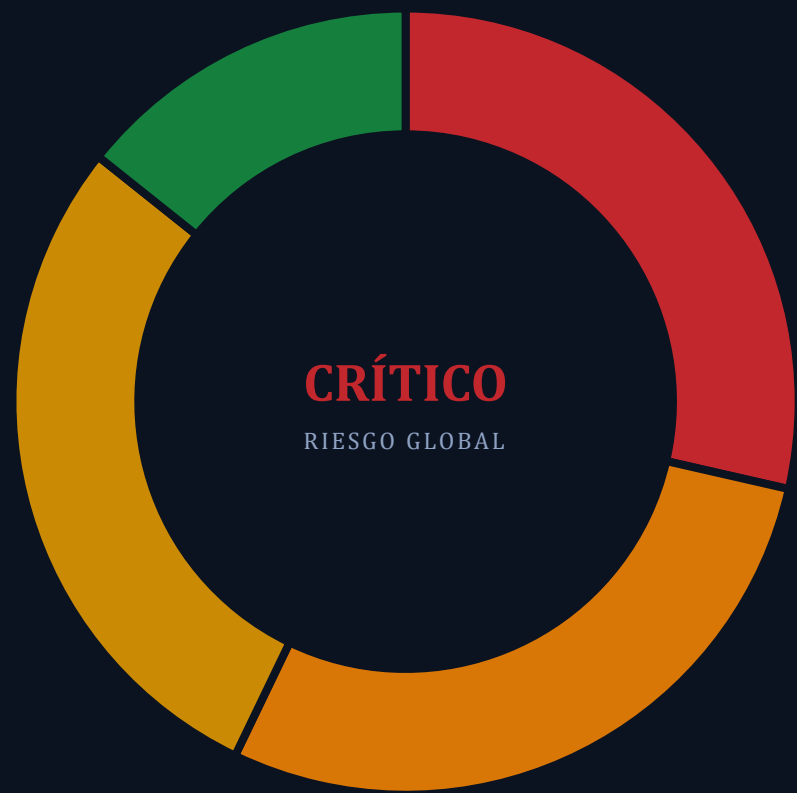
credenciales entregadas al inicio de la prueba

Un proceso estructurado, no un ataque improvisado

La evaluación siguió el Penetration Testing Execution Standard (PTES), el mismo marco de referencia que usan las firmas de ciberseguridad a nivel internacional.



El sistema fue comprometido en su totalidad



2

hallazgos críticos

2

hallazgos altos

3

hallazgos medios/bajos

El analista alcanzó acceso de administrador total (root) partiendo únicamente de una dirección IP visible en la red, sin credenciales previas.

DISTRIBUCIÓN DE LOS 7 HALLAZGOS POR SEVERIDAD



Dos fallas concentran la mayor parte del riesgo

CRÍTICO

Contraseñas expuestas públicamente

Un archivo accesible desde internet sin ninguna restricción contenía una contraseña real y funcional del sistema, entregando al analista las llaves de entrada sin romper ninguna protección.

CRÍTICO

Sistema operativo desactualizado explotable

Una falla conocida y públicamente documentada del sistema operativo (Dirty COW, 2016) permitió pasar de un usuario común a control administrativo total en menos de un minuto.

ALTO

Recursos de archivos sin control de acceso

Un repositorio de archivos compartidos permitía lectura y escritura sin autenticarse, habilitando al analista a depositar herramientas propias dentro del servidor.

Qué significa esto en términos de negocio



Confidencialidad

Cualquier archivo almacenado en el servidor —contratos, datos de clientes, información financiera— pudo haber sido leído o extraído sin dejar rastro visible.

Fuga de datos

Exposición de clientes



Integridad

Con control total, un atacante puede modificar o corromper documentos, contabilidad o registros, comprometiendo la confianza en la información del negocio.

Fraude interno

Registros alterados



Disponibilidad

El mismo acceso permite apagar el servidor o bloquear a los equipos internos, deteniendo la operación diaria de la organización.

Paro operativo

Pérdida de ingresos

En síntesis: el mismo punto de entrada que expuso las credenciales es suficiente, sin pasos adicionales de sofisticación, para afectar simultáneamente los tres pilares de seguridad de la información del negocio.

Probabilidad de explotación vs. impacto en el negocio

	IMPACTO BAJO	IMPACTO MEDIO	IMPACTO ALTO
PROB. ALTA			Credenciales expuestas · Falla de kernel
PROB. MEDIA		Recursos sin control de acceso	
PROB. BAJA		Configuración web desactualizada	

Cuatro decisiones para cerrar la brecha

01

Gestión de parches obligatoria

Establecer un proceso periódico de actualización de sistemas, con plazos máximos para aplicar parches críticos.

Dueño: TI / Infraestructura Horizonte: 90 días

02

Política de manejo de credenciales

Prohibir el almacenamiento de contraseñas en archivos de texto accesibles y adoptar un gestor de secretos corporativo.

Dueño: Seguridad Horizonte: 30 días

03

Control de acceso por defecto cerrado

Ningún recurso de archivos debe ser accesible sin autenticación; revisar todos los servicios expuestos a la red.

Dueño: TI / Infraestructura Horizonte: 30 días

04

Auditorías ofensivas recurrentes

Incorporar evaluaciones de este tipo como práctica periódica, no como evento aislado.

Dueño: Consejo / CISO Horizonte: Continuo

Plan de acción por horizonte de tiempo

0-7 DÍAS	30 DÍAS	90 DÍAS	CONTINUO
Cerrar la puerta abierta Retirar de inmediato el archivo con credenciales expuestas y aplicar el parche del kernel contra la falla de escalada de privilegios.	Reconfigurar accesos Exigir autenticación en los recursos compartidos de archivos y restringir los permisos de escritura de los servicios de transferencia.	Actualizar la base Actualizar los servicios web expuestos y aplicar una plantilla de configuración de seguridad estándar a todo el servidor.	Sostener el programa Institucionalizar la gestión de parches y las auditorías ofensivas como práctica recurrente, no como proyecto único.
Responsable: TI / Infraestructura	Responsable: Seguridad / TI	Responsable: TI / Infraestructura	Responsable: Consejo / CISO

El costo de remediar hoy es mucho menor que el de un incidente real

La evaluación demostró que el compromiso total del servidor de archivos fue posible combinando fallas individualmente simples de corregir. Ninguna requirió herramientas sofisticadas ni tiempo prolongado.

Se recomienda al Consejo autorizar la implementación inmediata de las medidas de contención y asignar presupuesto para un programa permanente de gestión de vulnerabilidades.

Decisión solicitada: aprobar el plan de remediación de 90 días

< 1 hora

tiempo total hasta obtener control root

4

acciones estratégicas propuestas al Consejo